

Actividad 01- Análisis y planificación de pentest

Yareli Yubiditzi Villagrana Mora

Hacker Women Council- Ethical Hacking

1. Objetivos

Aunque en una primera instancia, el equipo interno no encontró ninguna violación a la seguridad, esto no significa que realmente nunca existió, es por ello, que nuestro principal objetivo es evaluar la seguridad de la aplicación de Aurora Market con el fin de identificar aquellas fallas en el sistema que hacen que la aplicación sea vulnerable ante ataques, verificar que tan segura está realmente la información que los clientes están proporcionando y establecer medidas de seguridad posteriores al mapeo de vulnerabilidades, evitando así que ocurra algún ataque en el futuro.

2. Alcance

Si se evaluara:

- Aplicación web.
- Base de datos.
- Mecanismos de autenticación.
- Tipos de usuario.

Fuera del alcance:

- No hay información técnica de la infraestructura.
- No se conoce que tecnologías se utilizan.

3. Autorización y condiciones

- Autorización a solo evaluar la aplicación web.
- No se permite atacar las redes sociales de la empresa, equipos personales de los empleados, cuentas de correos, proveedores externos.
- Realizar pruebas solo en horarios de menor actividad.
- No interrumpir el funcionamiento de la plataforma.

4. Tipo de pentest

El tipo de pentest es Black Box, ya que no se nos proporcionó la información de la infraestructura y no se nos otorgó permisos completos, por lo que si bien, será una evaluación más rápida, ya que solo trabajaremos con lo poco que tenemos, al no poder adentrarnos más a la infraestructura, existe el

riesgo de que se nos escape alguna entrada o vulnerabilidad que pueda aprovechar el atacante para infiltrarse en Aurora Market.

5. Planificación

Objetivos

Evaluar la seguridad de la aplicación de Aurora Market con el fin de identificar aquellas fallas en el sistema que hacen que la aplicación sea vulnerable ante ataques, verificar que tan segura está realmente la información que los clientes están proporcionando y establecer medidas de seguridad posteriores al mapeo de vulnerabilidades, evitando así que ocurra algún ataque en el futuro.

Alcance

Aplicación web, base de datos, mecanismos de autenticación, tipos de usuario.

Permisos y condiciones

Realizar pruebas solo en horarios de menor actividad, evaluar solo la aplicación web, no atacar redes sociales de la empresa, equipos personales de los empleados, cuentas de correos, proveedores externos y no interrumpir el funcionamiento de la aplicación.

Metodología a utilizar

La metodología a utilizar es la OWASP ya que está enfocada en las aplicaciones web, identificar problemas de seguridad más comunes y como reducirlos y, para este escenario, es el más adecuado de aplicar. También utilizaremos PTES ya que te muestra de inicio a fin como realizar de manera correcta un pentest y las 7 fases que representan esta herramienta, son algo que se adapta a la metodología que estamos empleando en este trabajo, ya que estamos yendo paso por paso para poder analizar de manera correcta las vulnerabilidades en Aurora Market y como realizar un informe detallado que permita a la empresa identificar sus fallas y como actuar ante ellas.

Recopilación de información previa

Como no tenemos acceso completo a la información e infraestructura de Aurora Market y estamos trabajando bajo un enfoque de caja negra, deberemos realizar una búsqueda exhaustiva fuera de los sistemas, la herramienta OSINT nos será de gran utilidad en este escenario ya que podemos encontrar toda la información en bases de datos públicas que podrían ayudar a un atacante a conocer mas sobre la empresa, como trabaja, que datos recopila, etc. de esta manera sabremos también que información

de la empresa y clientes podría estar expuesta a internet y si existe alguna filtración de información. Realizaremos mapeo de la aplicación actuando como un cliente y de esta manera conocer el funcionamiento de la aplicación, los datos que está recopilando y así no violar algún acuerdo pactado.

Recursos necesarios

- Computadora
- Acceso a internet
- Acceso a la aplicación web
- OSINT
- OWASP
- PTES

Programación del pentest

Se planea ejecutar las pruebas por la madrugada que es cuando menor fluctuación de usuarios se observa en la página web. El horario específico se designó de 1:00am a 4:00 am. De esta manera, podremos evitar que si existe alguna falla en la aplicación debido a la prueba, no genere muchas pérdidas ni afecte a tantos usuarios.

6. Fases del pentest

Reconocimiento

Iniciaremos con un análisis con enfoque OSINT para conocer de manera externa a la empresa y si existe alguna filtración de datos en la red y como es que está funciona, esto nos permitirá rescatar más información de la empresa, ya que esta no nos proporcionó muchos datos, también analizaremos la aplicación como si fuéramos usuarios para conocer a fondo su funcionamiento y detectar de esta manera algún punto de acceso que pueda ser vulnerable, al analizar de esta manera la aplicación tendremos un enfoque de lo que ve cada usuario y si es real el problema que se reportó al inicio. Como metodología utilizaremos PTES para el desarrollo correcto de pentest y OWASP por su enfoque en identificar problemas y mitigarlos. Como estamos trabajando base a condiciones específicas que no nos permiten una investigación exhaustiva fuera de la aplicación, he decidido no analizar los puertos para evitar una violación de los acuerdos.

Análisis de vulnerabilidades

OWASP será nuestra metodología clave para analizar las vulnerabilidades, ya que con su enfoque de Top 10, podemos investigar cada uno de los puntos que se mencionan como riesgos de seguridad e ir investigando y descartando cada uno de ellos en caso de no encontrar nada fuera de lugar o que pueda

representar un riesgo para la empresa, hacerlo de esta manera me ayuda a tener un enfoque mas controlado sobre lo que estoy buscando y no dejar un sesgo que pueda convertirse en un riesgo para la empresa y usuarios.

Explotación

Como anteriormente, con ayuda de la metodología OWASP pudimos detectar las vulnerabilidades, ahora en este punto vamos a identificar que realmente sean verdaderos positivos, porque por ejemplo en el caso del usuario que reportó el incidente, cuando lo revisó el equipo interno, resulto ser un falso negativo, ya que no encontraron nada fuera de lugar pero si se reportó un incidente. Así que nuestro enfoque en este punto es verificar las vulnerabilidades encontradas.

Post explotación

Una vez que hayamos encontrado aquellas vulnerabilidades más preocupantes para la empresa, vamos a profundizar en ellas para observar que tanto las podemos explotar y medir el alcance que tendría que el atacante aprovechara estas vulnerabilidades en el sistema y que tanto afectaría a los usuarios y a la empresa.

Informe

Una vez analizado todo el panorama, probado la aplicación y detectado aquellas vulnerabilidades que presentan una amenaza real para Aurora Market y los usuarios, redactaremos un informe detallando los problemas que hemos identificado, como es que logramos percatarnos de estas vulnerabilidades, cuándo es que se presentan los riesgos y cuál es la manera más optima de reducirlos y evitar las amenazas encontradas en el sistema. Siempre mostrando evidencias reales de las vulnerabilidades que hemos encontrado.

7. Investigación

La metodología OWASP es la más adecuada para este escenario, ya que de las que vimos en clase, esta es la que mas se enfoca en las aplicaciones web y se centra en identificar problemas de seguridad mas comunes y como evitar y reducir aquellos problemas encontrados.

La manera en la que está detallado el top 10 es una herramienta muy útil, ya que detalla los diez riesgos de seguridad mas comunes dentro de las aplicaciones web y analizando estos puntos y con lo que comunicó el usuario que encontró uno de los problemas, existiría un fallo en el control de acceso roto y un fallo criptográfico, ya que según este reporte, había una filtración de datos personales.

También la metodología PTES es acertada ya que nos ayuda a entender mejor la estructura del pentest y como es que debemos de realizar cada punto.